

CUADERNILLO DE ESTUDIO

CLASE 11

*“Gobierno de la seguridad:
Política de Seguridad Aceptable”*

▲ Incluye PARCIAL 2

Profesor: Mg. Ing. Rodrigo Atilio Elgueta

Unidad: Unidad 4

Datos del/la estudiante

Nombre y apellido: _____

Grupo N.º: _____

Negocio Digital (TP): _____

Fecha: _____

Índice

1. De la técnica al gobierno: el tablero de la seguridad	2
2. La pirámide documental: políticas, normas y procedimientos	3
3. La Política de Seguridad Aceptable (PSA)	4
3.1. ¿Por qué es tan importante?	4
3.2. Estructura mínima de una PSA	4
4. Roles y responsabilidades en seguridad	6
5. PARCIAL 2: caso, formato y rúbrica	7
5.1. Caso del Parcial 2: “DevCraft”	7
5.2. ¿Qué deben entregar?	7
5.3. Rúbrica oficial del Parcial 2 (sobre 10 puntos)	8
6. Plantilla de redacción para el Parcial 2	9
7. Preparación para la defensa oral	12
7.1. Estructura recomendada de la presentación (5 min)	12
7.2. Preguntas individuales típicas del docente	12
8. Glosario de la Clase 11	14
9. Cierre y puente hacia la Clase 12	14
10. Espacio para notas y preparación del Parcial 2	15

1. De la técnica al gobierno: el tablero de la seguridad

En las unidades anteriores aprendimos a proteger sistemas (Unidad 1 y 2), a cumplir la ley (Unidad 3) y a concientizar personas (Clase 10). Pero todo eso puede quedar como acciones aisladas si la organización no tiene **reglas claras del juego**.

Definición

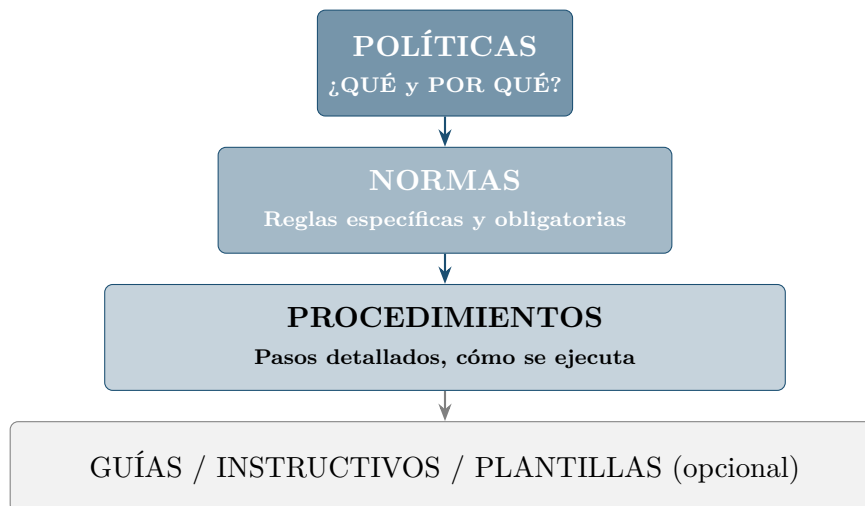
El **Gobierno de la Seguridad** es el conjunto de políticas, normas, procedimientos, roles y responsabilidades que una organización establece para dirigir, controlar y mejorar continuamente su seguridad de la información.

La diferencia fundamental

La **seguridad técnica** dice *cómo* se protegen los sistemas (firewalls, cifrado, MFA). El **gobierno de la seguridad** dice *quién decide qué se protege, por qué, y qué pasa si no se cumple*. Sin gobierno, la seguridad es un conjunto de herramientas sin estrategia.

2. La pirámide documental: políticas, normas y procedimientos

El gobierno de la seguridad se materializa en documentos organizados jerárquicamente. Cada nivel tiene un propósito distinto.



Nivel	¿Qué es?	Ejemplo
Política	Declaración de intención de la dirección. Establece el “qué” y el “por qué”. Es estable en el tiempo.	“Todos los datos de clientes se cifran en reposo y tránsito.”
Norma	Regla obligatoria y específica que desarrolla la política.	“Se usa AES-256 para datos en reposo; TLS 1.2 o superior para datos en tránsito.”
Procedimiento	Pasos detallados para cumplir la norma. Es operativo.	“Paso 1: generar clave en el KMS. Paso 2: configurar el bucket S3 con SSE-KMS. Paso 3: auditar trimestralmente.”

Si una empresa solo tiene **procedimientos** sin políticas, nadie sabe *por qué* se hacen las cosas y todo depende de personas específicas. Si solo tiene **políticas** sin procedimientos, las buenas intenciones no se ejecutan. El equilibrio entre los tres niveles es lo que hace que la seguridad sea **sostenible**.

3. La Política de Seguridad Aceptable (PSA)

Definición

La **Política de Seguridad Aceptable** (en inglés, Acceptable Use Policy, AUP) es el documento que establece **qué pueden y qué no pueden hacer los empleados y usuarios** con los recursos tecnológicos de la organización (equipos, red, internet, correo, aplicaciones, datos).

3.1 ¿Por qué es tan importante?

- **Legal:** da respaldo para aplicar sanciones ante incumplimientos (un empleado que usa la notebook de la empresa para minar criptomonedas, por ejemplo).
- **Claridad:** elimina zonas grises; todo el mundo sabe qué está permitido.
- **Cultura:** instala la seguridad como parte del contrato laboral, no como una molestia externa.

3.2 Estructura mínima de una PSA

Una PSA profesional suele tener estos bloques:

Sección	¿Qué contiene?
1. Propósito y alcance	¿Para qué existe la política? ¿A quién aplica? (empleados, contractors, terceros).
2. Uso aceptable de los recursos	Qué usos están permitidos (trabajo, uso personal razonable) y cuáles prohibidos.
3. Contraseñas y accesos	Requisitos mínimos de contraseñas, uso de gestores, MFA, prohibición de compartir credenciales.
4. Correo e internet	Uso aceptable del correo corporativo y la conexión a internet; sitios prohibidos; manejo de adjuntos.
5. Dispositivos	Uso de equipos corporativos, BYOD (“traé tu propio dispositivo”), pérdida o robo.
6. Información y datos confidenciales	Clasificación de datos, manejo, prohibición de fugas, redes sociales.
7. Incidentes	Obligación de reportar incidentes de seguridad.
8. Cumplimiento y sanciones	Qué pasa si no se cumple (desde advertencia hasta despido o acciones legales).
9. Firmas y vigencia	Firma del empleado, firma del responsable, fecha de vigencia y revisión.

Una PSA debe ser **corta, clara y específica**. Si es un documento de 40 páginas en lenguaje legal, nadie la lee y no sirve. Las mejores PSA caben en 2-4 páginas y se firman al ingresar a la empresa.

4. Roles y responsabilidades en seguridad

El gobierno también define **quién es responsable de qué**. Los roles más comunes en una organización digital son:

Rol	Responsabilidad principal
Dirección / CEO	Aprueba la política y asigna presupuesto. Es el responsable último.
CISO (Chief Information Security Officer)	Lidera la estrategia de seguridad, reporta a la dirección.
DPO (Data Protection Officer)	Vela por el cumplimiento de la normativa de datos personales (Ley 25.326 / GDPR).
Dueño del activo (Asset Owner)	Responsable de un activo específico (ej. el Gerente Comercial es dueño de la base de clientes).
Área de TI / Seguridad	Implementa controles técnicos, monitorea, responde incidentes.
Todos los empleados	Cumplen la PSA, reportan incidentes, protegen sus credenciales.

El error frecuente en las pymes

En empresas chicas no suele haber un CISO ni un DPO dedicados. Pero **los roles deben existir aunque los ocupe la misma persona**. Lo importante es que alguien sea formalmente responsable de la seguridad, de los datos personales y del cumplimiento. Si “todos son responsables”, nadie lo es.

5. PARCIAL 2: caso, formato y rúbrica

Modalidad:	Grupal (mismos grupos del TP Integrador), en clase.
Duración:	60 minutos de redacción + 5 minutos de defensa oral por grupo.
Cobertura:	Unidades 3 y 4 + temas transversales (nube, criptografía, hacking ético).
Entregable:	Una Política de Seguridad Aceptable (PSA) para el caso dado.
Nota:	1 a 10. Se aprueba con 4.

5.1 Caso del Parcial 2: “DevCraft”

Contexto: “DevCraft” es una empresa de desarrollo de software con 40 empleados. Hace aplicaciones a medida para clientes (bancos, retailers, startups).

Equipo:

- 25 desarrolladores (muchos trabajan remoto o híbrido, usan notebooks propias y corporativas).
- 5 diseñadores UX/UI.
- 3 project managers.
- 2 personas en RRHH.
- 2 en administración/finanzas.
- 1 gerente general.
- 2 personas en “infraestructura/DevOps” (manejan la nube de la empresa).

Situación: La empresa creció rápido y nunca tuvo una política formal. Recientemente un desarrollador subió código con credenciales de AWS a un repositorio público de GitHub, y un cliente se quejó de que su informón confidencial podría haber quedado expuesta. El director decidió que **es hora de tener una PSA formal**.

5.2 ¿Qué deben entregar?

Cada grupo debe redactar una **PSA completa para DevCraft**, con las 9 secciones vistas en la Sección 3, adaptadas al caso. Debe ser:

- **Realista** para una empresa de 40 personas (no pedir controles de multinacional).
- **Específica** sobre los riesgos reales del caso: trabajo remoto/híbrido, BYOD, código con credenciales, datos de clientes bancarios.
- **Coherente** con el marco normativo (Ley 25.326, derechos ARCO) y los temas transversales vistos (nube, criptografía, hacking ético).

5.3 Rúbrica oficial del Parcial 2 (sobre 10 puntos)

¿Qué se evalúa?	Puntos
Complejidad y pertinencia de la PSA para el caso dado	hasta 3
Alineación con el marco normativo y de gobierno visto en clase	hasta 2
Calidad de la defensa oral grupal (claridad, argumentación)	hasta 2
Calidad de las respuestas individuales a las preguntas del docente	hasta 3
TOTAL	10

Atención: las preguntas individuales valen 30 %

El Parcial 2 no solo evalúa el documento escrito, sino la **comprensión individual**. El docente hará preguntas cruzadas a cada integrante del grupo. Todos deben poder explicar cualquier parte de la PSA.

6. Plantilla de redacción para el Parcial 2

Durante el Parcial 2 van a redactar la PSA de DevCraft en esta plantilla. Pueden usar el reverso o hojas adicionales si es necesario. Al terminar, la firman como grupo y la entregan al docente.

POLÍTICA DE SEGURIDAD ACEPTABLE

DevCraft — Versión 1.0

1. Propósito y alcance

2. Uso aceptable de los recursos

3. Contraseñas y accesos

4. Correo e internet

5. Dispositivos (incluye BYOD y trabajo remoto)

6. Información y datos confidenciales (incluye código fuente)

7. Reporte de incidentes

8. Cumplimiento y sanciones

9. Vigencia y firmas

7. Preparación para la defensa oral

Al terminar la redacción, cada grupo tiene **5 minutos** para presentar su PSA al resto de la clase y al docente. Luego, el docente hará preguntas individuales.

7.1 Estructura recomendada de la presentación (5 min)

1. **1 minuto** — Contexto: por qué DevCraft necesitaba una PSA (el incidente del repositorio).
2. **2 minutos** — Los 3-4 puntos más importantes de su PSA (los que priorizaron).
3. **1 minuto** — Cómo van a lograr que los empleados la conozcan y la cumplan (capacitación, firma al ingreso, recordatorios).
4. **1 minuto** — Cómo se revisará y actualizará la política en el tiempo.

7.2 Preguntas individuales típicas del docente

Estas son **ejemplos reales** de preguntas que el docente puede hacer a cada integrante del grupo. Practíquenlas antes de la defensa:

Sobre el caso:

- ¿Por qué incluyeron esta regla sobre código fuente y repositorios?
- ¿Cómo manejarían el hecho de que muchos desarrolladores trabajan con notebooks propias?
- ¿Qué hacen si un empleado se niega a firmar la PSA?

Sobre el marco normativo:

- ¿Su PSA respeta la Ley 25.326? ¿Cómo?
- ¿Qué derechos ARCO debería conocer cada empleado?
- ¿Cómo se relaciona esta PSA con la política de privacidad de la empresa?

Sobre temas transversales:

- Si DevCraft usa AWS, ¿qué parte de la seguridad es responsabilidad de la empresa y cuál de AWS?
- ¿Cómo se conecta esta PSA con lo que vieron de hashing y criptografía?
- ¿Qué rol tiene la concientización (clase 10) para que la PSA se cumpla?

Sobre gobierno:

- ¿Quién es el responsable último de la seguridad en DevCraft?
- ¿Cómo se revisa y actualiza esta política?
- ¿Qué pasa si un gerente incumple la política?

Consejos para la defensa

1. **Distribuyan roles** para la presentación: quién introduce, quién explica los puntos clave, quién cierra.
2. **Todos deben estar listos para responder** preguntas individuales. Repasen la PSA juntos antes de presentar.
3. **Sean honestos** si no saben algo: es mejor decir “lo discutimos pero no lo resolvimos” que inventar.
4. **Usen ejemplos concretos** del caso DevCraft, no generalidades.

8. Glosario de la Clase 11

Término	Definición en una línea
Gobierno de la seguridad	Estructura de políticas, roles y procesos que dirigen la seguridad.
Política	Declaración de intención de la dirección (el “qué” y el “por qué”).
Norma	Regla específica y obligatoria que desarrolla la política.
Procedimiento	Pasos operativos detallados para cumplir una norma.
PSA / AUP	Política de Seguridad Aceptable (Acceptable Use Policy).
CISO	Director de Seguridad de la Información (rol ejecutivo).
DPO	Delegado de Protección de Datos.
Dueño del activo	Persona responsable de un activo específico.
BYOD	“Bring Your Own Device”; empleados usan dispositivos propios.
Vigencia	Fecha desde la cual una política es válida.

9. Cierre y puente hacia la Clase 12

- La diferencia entre **seguridad técnica** y **gobierno de la seguridad**.
- La **pirámide documental**: políticas → normas → procedimientos.
- La estructura de una **PSA** completa y su importancia legal y cultural.
- Los **roles** clave en seguridad (CISO, DPO, dueños de activos).
- Experiencia real de redactar y defender una PSA (Parcial 2).

Puente hacia la Clase 12: Factor humano e incidentes

Una PSA es el **piso** del gobierno. Pero ni la mejor política evita que los incidentes ocurran. La próxima clase vamos a ver qué hacer **cuando algo sale mal**: cómo gestionar un incidente, cómo reacciona la organización, y por qué el factor humano es a la vez el eslabón más débil y el más importante.

Además, prepararemos la **Junta de Crisis** de la Clase 12 (un juego de roles donde cada integrante toma un papel durante una filtración de datos).

10. Espacio para notas y preparación del Parcial 2

Usá este espacio para anotar ideas para la PSA, dudas sobre el caso DevCraft, o posibles respuestas a las preguntas individuales del docente.